

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

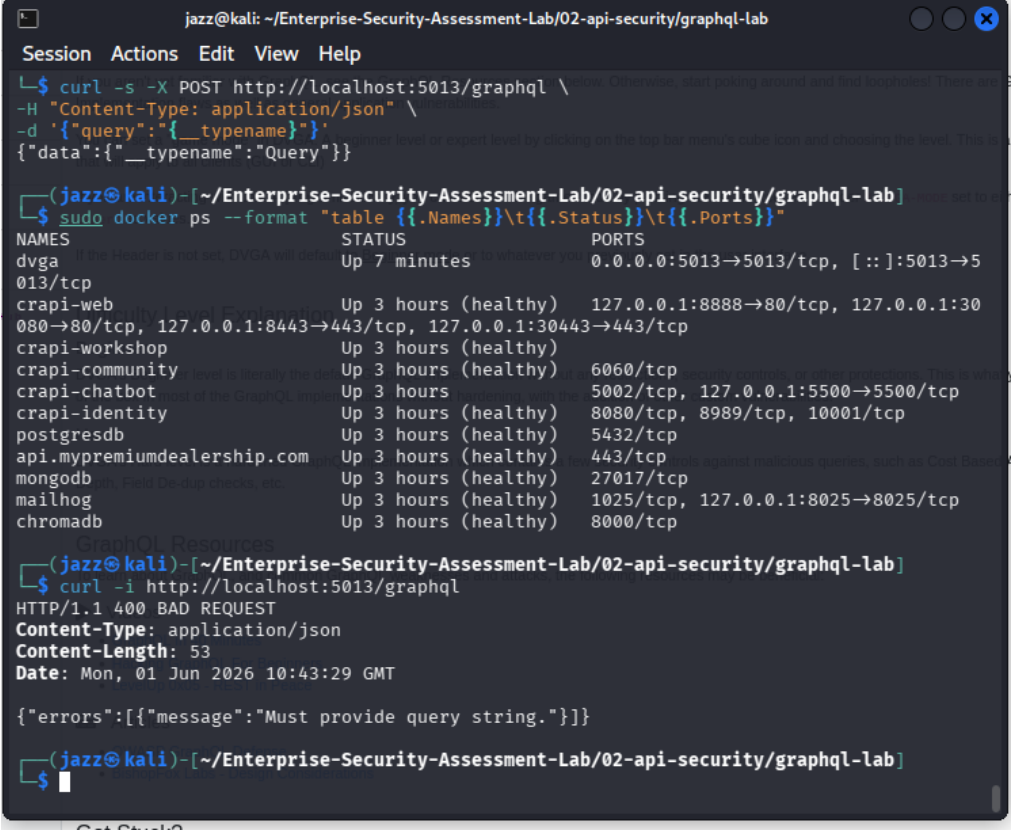
crAPI Docker Container Deployment Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	crAPI containers running
Result Type	Lab deployment proof
Evidence Report File	00-crapi-docker-containers-running-evidence-report.pdf
Testing Phase	API Lab Deployment and Service Readiness
Tool / Component	Docker / Terminal
OWASP / Security Mapping	Preparation / Assessment Evidence
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot



```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab
Session Actions Edit View Help

$ curl -s -X POST http://localhost:5013/graphql \
-H "Content-Type: application/json" \
-d '{"query":"{__typename}"}'
{"data":{"__typename":"Query"}}

(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab]
$ sudo docker ps --format "table {{.Names}}\t{{.Status}}\t{{.Ports}}"
NAME                STATUS              PORTS
dvga                Up 7 minutes       0.0.0.0:5013→5013/tcp, [::]:5013→5
013/tcp
crapi-web           Up 3 hours (healthy) 127.0.0.1:8888→80/tcp, 127.0.0.1:30
080→80/tcp, 127.0.0.1:8443→443/tcp, 127.0.0.1:30443→443/tcp
crapi-workshop      Up 3 hours (healthy)
crapi-community     Up 3 hours (healthy) 6060/tcp
crapi-chatbot       Up 3 hours          5002/tcp, 127.0.0.1:5500→5500/tcp
crapi-identity      Up 3 hours (healthy) 8080/tcp, 8989/tcp, 10001/tcp
postgresdb          Up 3 hours (healthy) 5432/tcp
api.mypremiumdealership.com Up 3 hours (healthy) 443/tcp
mongodb             Up 3 hours (healthy) 27017/tcp
mailhog             Up 3 hours (healthy) 1025/tcp, 127.0.0.1:8025→8025/tcp
chromadb            Up 3 hours (healthy) 8000/tcp

(jazz@kali)-[~/Enterprise-Security-Assessment-Lab/02-api-security/graphql-lab]
$ curl -i http://localhost:5013/graphql
HTTP/1.1 400 BAD REQUEST
Content-Type: application/json
Content-Length: 53
Date: Mon, 01 Jun 2026 10:43:29 GMT

{"errors":[{"message":"Must provide query string."}]}
```

Figure 1 - Embedded screenshot evidence for: crAPI containers running

What this evidence proves

The evidence shows Docker container output for the crAPI stack, proving that the intentionally vulnerable API lab was started locally and the assessment target was controlled by the tester.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	API Lab Deployment and Service Readiness
Tool / Component	Docker / Terminal
Assessment Objective	Confirm that the crAPI lab containers are deployed and running before API security testing begins.
Result Type	Lab deployment proof
OWASP / Security Mapping	Preparation / Assessment Evidence

Why this evidence matters

Environment validation is the first control point in any professional assessment. It proves that the work was performed against a known lab target and that later API requests were not sent to an unauthorized service.

Command / workflow used

```
docker ps
docker compose ps
# verify crAPI service containers, ports, and status before testing
```

Sanitized output style

CONTAINER ID	IMAGE / SERVICE	STATUS	PORTS
<redacted>	crapi-web	Up	0.0.0.0:8888->8888/tcp
<redacted>	mongodb / mailhog	Up	lab internal ports

3. Professional Interpretation

This evidence row should be interpreted as: **Lab deployment proof.**

This is not a vulnerability. It is environment evidence. In professional reporting, deployment evidence prevents confusion between authorized lab testing and external testing.

Assessor notes

Useful as first proof that the API lab was built and active.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Important reporting distinction

This row is setup or workflow evidence. It supports the assessment chain but should not be described as a security finding by itself.

4. Risk, Impact, and Remediation Guidance

Risk perspective

This is not a vulnerability. It is environment evidence. In professional reporting, deployment evidence prevents confusion between authorized lab testing and external testing.

Recommended remediation / hardening actions

- Keep vulnerable labs isolated from public networks.
- Stop containers when the lab is complete.
- Do not expose crAPI to the internet.
- Document container ports and cleanup status.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Local usernames and shell paths if private.
- Container IDs if you prefer minimal disclosure.
- Any environment variables or secrets if displayed.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[crAPI containers running](./reports/evidence/00-crapi-docker-containers-running-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.